



University of
BRISTOL



Investigating the process of secure boot in IoT devices

Andy Baldrian



UNIVERSITY OF
BATH

Andy Baldrian

PhD researcher

Research area:
developer-centred
security, looking at
how to make IoT
devices more secure.

30+ year in the software industry, as
developer, architect, VP of Engineering
and CTO.





- Booting a device
- Root of Trust
- A bit of crypto
- Secure boot process
- Signing and validating an image
- Implications for developers

Bootloader – Bootstrapping

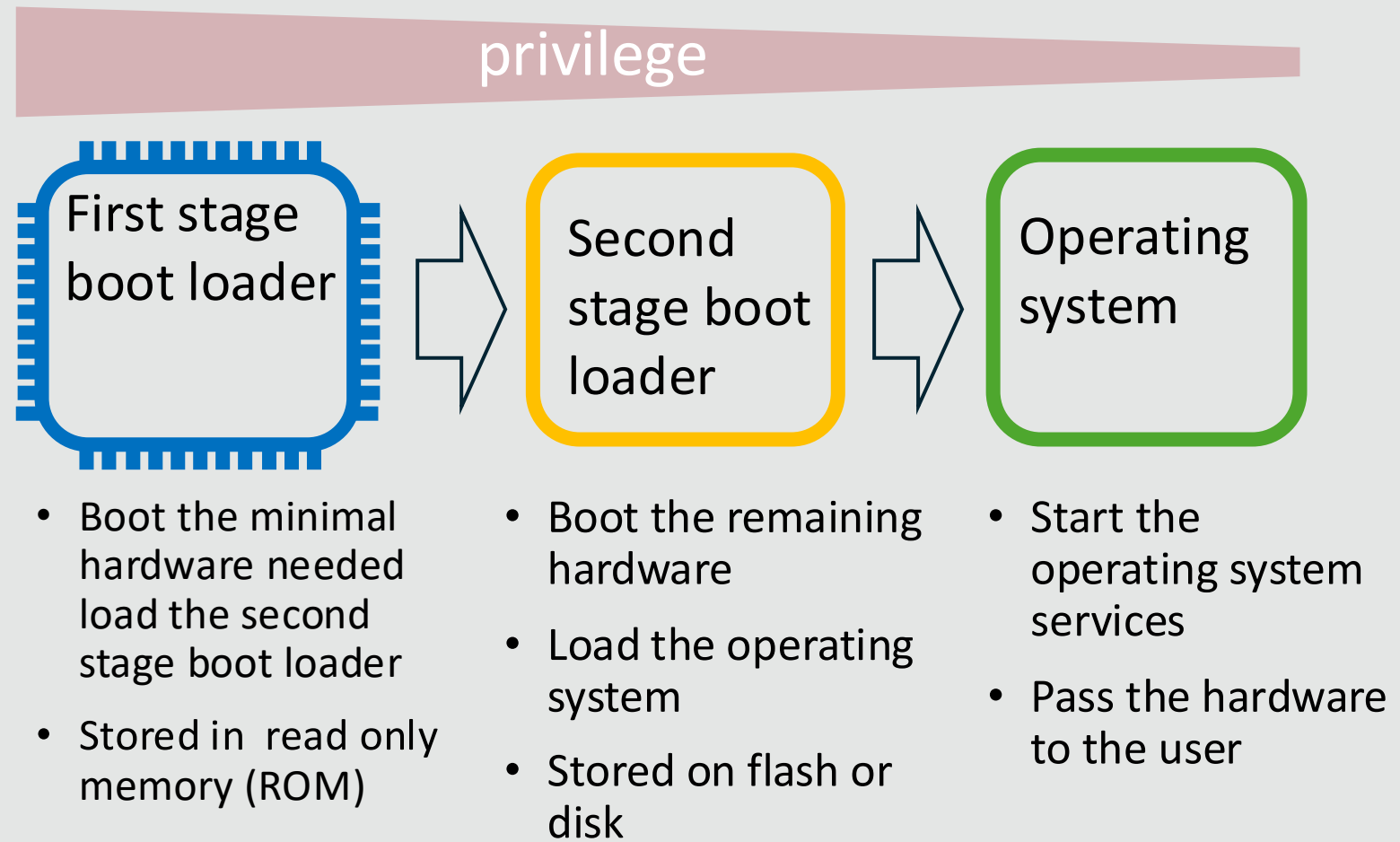
Pull oneself up by one's bootstraps

- First attributed to an article in the *Workingman's Advocate* (1834)
- Documented use of the term **bootstrap load** (1953) in computing.
 - Shortened to boot
- Process of starting up a computer system by loading the operating system into memory

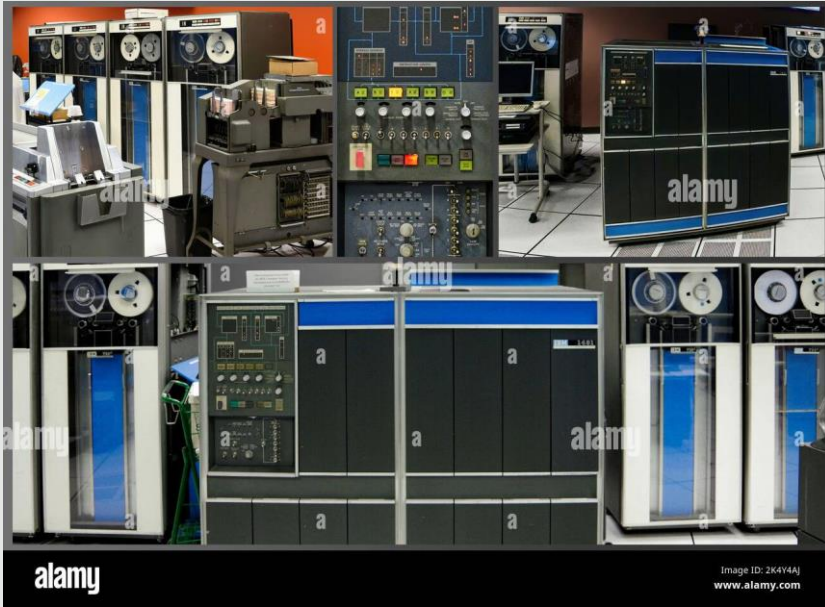


Bootloader – Booting the hardware

- Booting is act of initialising the hardware and loading the right software.
- Often in two stages.
- The first stage is specific to the hardware.
- The second stage is often a generic bootloader
 - Grub
 - U Boot
 - MUC Boot



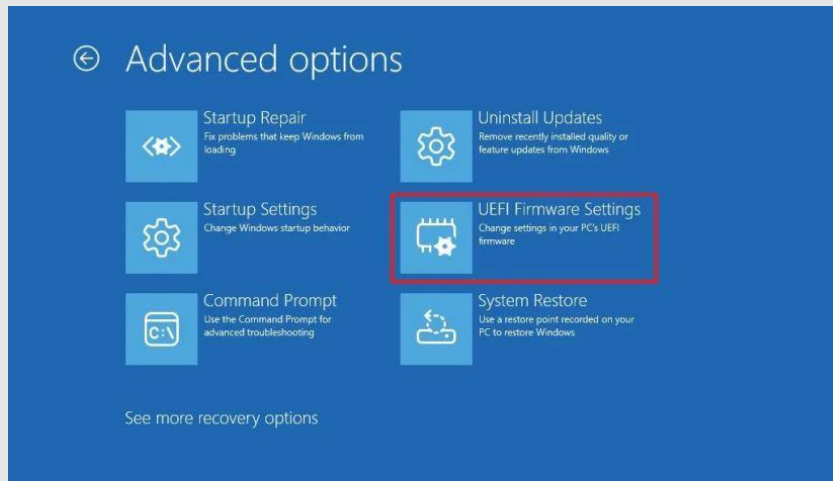
Secure boot



"AEGIS is a guaranteed secure boot process that ensures that the computer system is started via a trusted process"

Arbaugh, Farber, & Smith (1997).

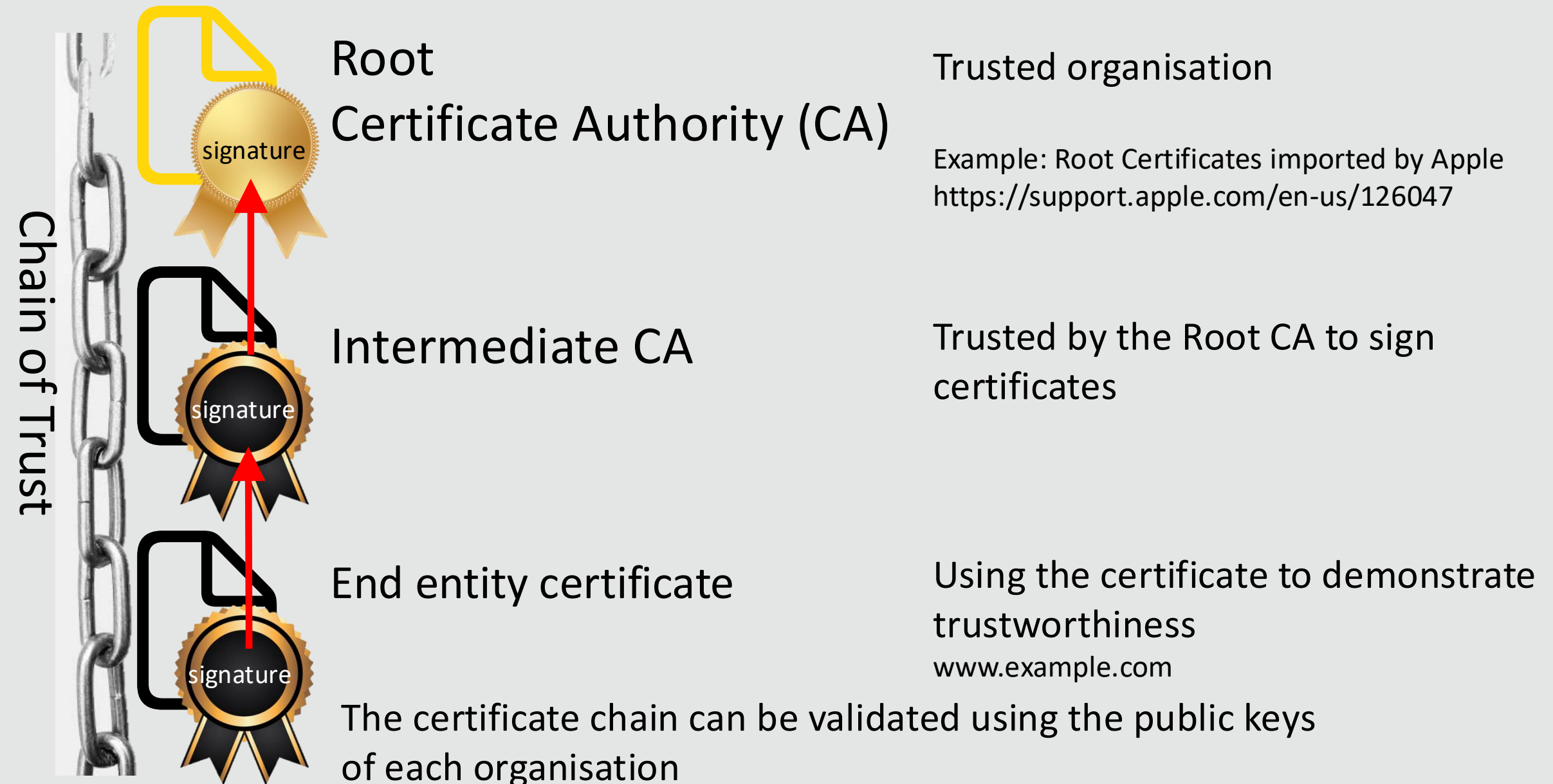
Secure boot is the process of validating each boot stage before running the software.



- Secure boot is now a fundamental security feature,
 - Found in laptops, phones, IoT devices etc.
 - Unified Extensible Firmware Interface (UEFI)
- Secure boot forms part of a Root of Trust.

What is a Root of Trust?

Example form Public Key Infrastructure (PKI)



What is a Root of Trust?



Is the Root CA a Root of Trust?

- Can we trust the Root CA?
 - What happens if the private key is stolen?
 - DigiNotar Certificate Authority breach
- Can we trust the list of Root CA that the browser is using?
 - What happens if Root CA is added?
- Ultimately the question we need to ask is can we trust the software that is running and the hardware that it is running on?
 - Secure boot is the process of validating the boot process so that we can trust the software that we are running.



What is a Root of Trust?

- “Highly reliable hardware, firmware, and software components that perform specific, critical security functions”. NIST SP 800-172
- “A starting point that is implicitly trusted”. NISTIR 8320
- “The foundational security component of a connected device”. PSA Certified

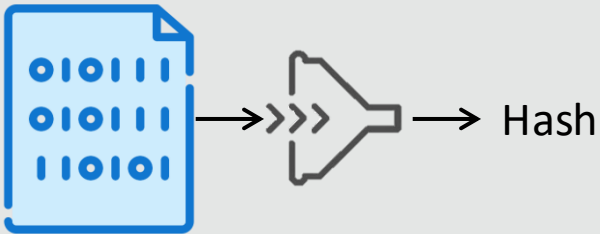


In the case of secure boot:

- A Root of Trust is the **secure** immutable start of an **authenticated** chain of trust.
- The Root of Trust is the start of **all** security guarantees provided by the computing systems.

A bit of crypto – Hash functions

- A hash function takes an input of any size and converts it into a fixed-length.

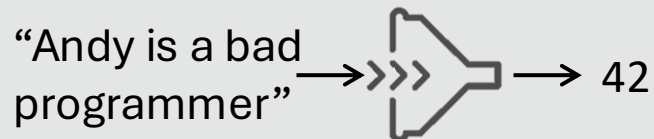


Bad example:

$$\left(\sum_{i=0}^n M(i) \right) \text{ Mod } 256$$

Example: hash algorithms

- Argon2i
- Crypt_MD5
- SHA-256



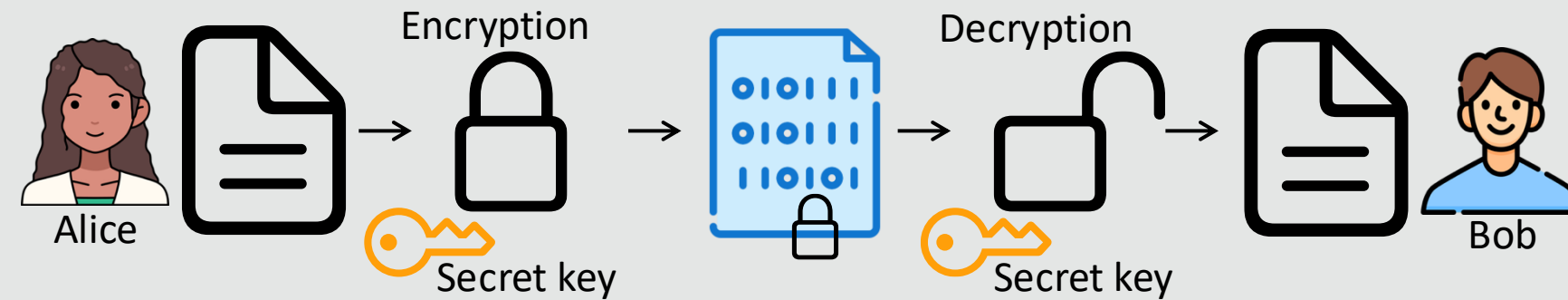
Properties of a cryptographic hash:

- **Determinism**
 - The same input should generate the same output
- **Pre-Image Resistance**
 - It should be difficult to recreate the original input from the hash.
- **Collision Resistance**
 - It should be difficult to create a new file that will give the same hash.
- **Avalanche Effect**
 - A small change in input should generate a large change in the hash

A bit of crypto – Encryption

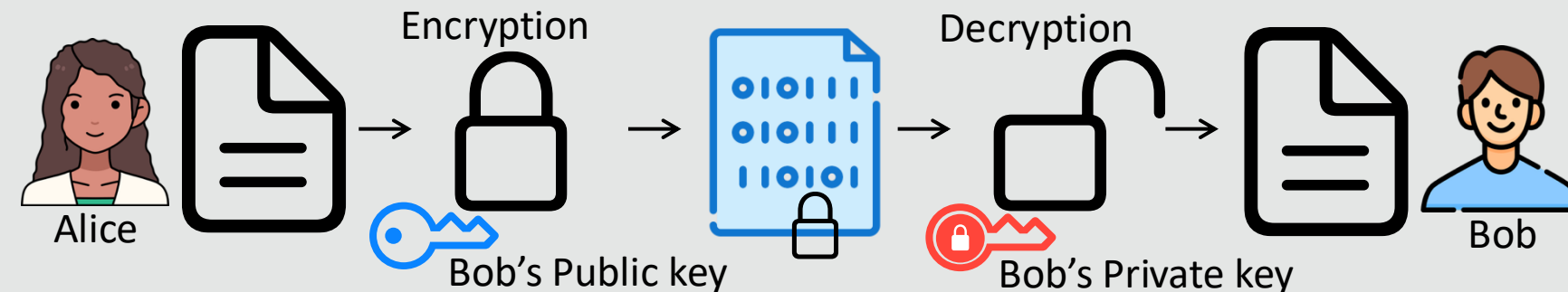
Alice wants to send a secret message to Bob

Symmetric encryption



The same key is used for encryption and decryption.

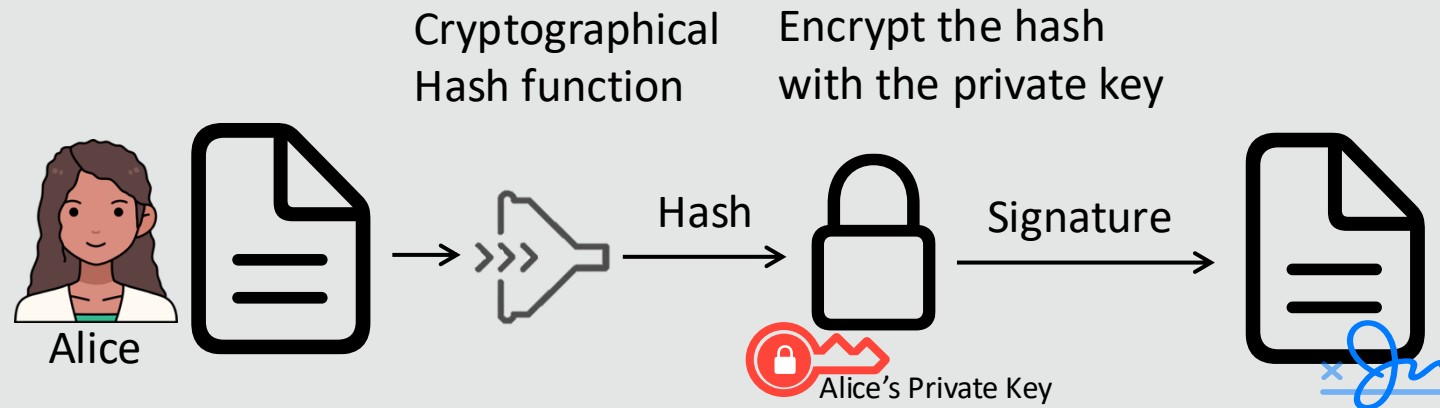
Asymmetric encryption



The public key is used for encryption and the Private key for decryption.

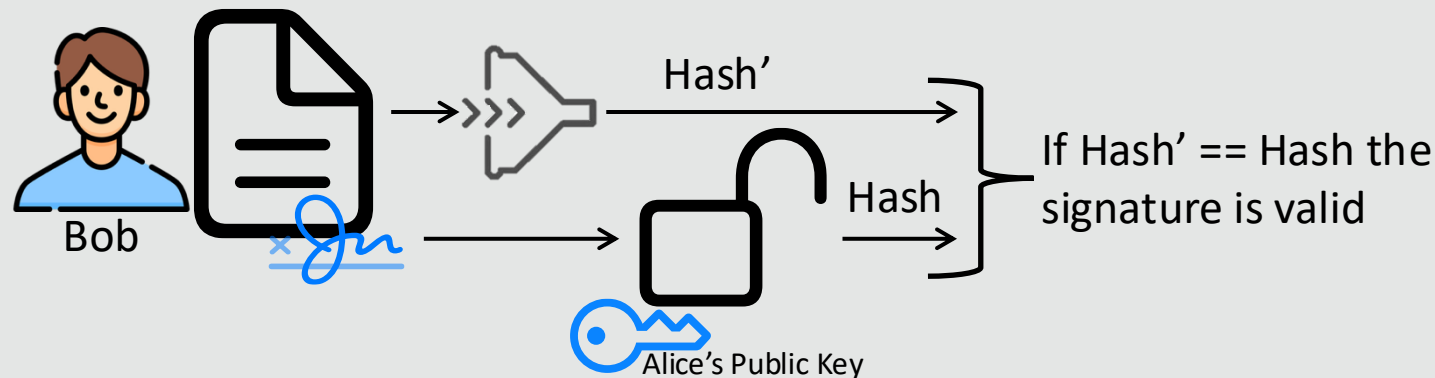
A bit of crypto – Digital signature

Alice wants to sign a document



- The private key is used to encrypt the hash
- Anyone with the public key can decrypt the hash and validate the signature

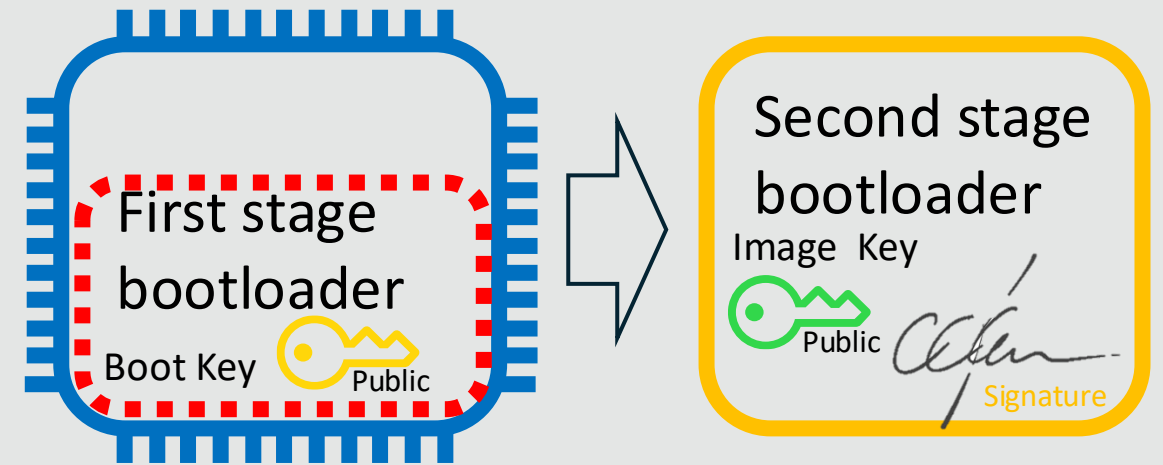
Bob needs to validate the signature



Only the entity in possession of the private key could have signed the document

Secure boot

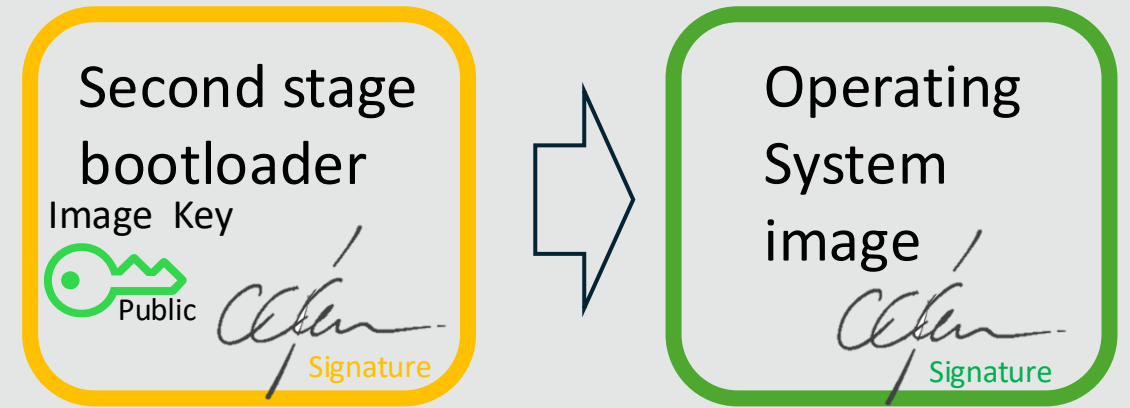
- The first stage bootloader runs in a secure environment, such as:
 - Trusted Platform Module: a secure crypto processor that implements the ISO/IEC 11889 standard,
 - Trusted Execution Environment: a secure area of a processor.



- The software for the first stage bootloader is stored in immutable (ROM) or protected memory.
- The second stage image is signed using the private boot key.
- The first stage bootloader has a public boot key that it uses to validate the second stage image.
- The first stage bootloader validates the second stage image before running it.

Secure boot

- The second stage bootloader may also run in the secured environment.
- The bootloader uses a similar process to validate the OS image before loading it.
- The second stage bootloader can be updated
 - This allows for updated cryptographic algorithms, certificates and keys
- The bootloader image may also be encrypted
 - The decryption key must also be provisioned to the device.
 - The first stage bootloader can then decrypt and validate the second stage image.
- Likewise, the OS image can also be encrypted



Secure boot – In IoT devices

The term "*Internet of Things*" was first coined by **Kevin Ashton** in 1999 "as the title of a presentation", it defines a connected device that interacts with the world around it. "*We need to empower computers with their own means of gathering information, so they can see, hear and smell the world for themselves, in all its random glory*".

- IoT devices are connect to the network, with sensors and actuators
 - Microphones, cameras, motors etc.
- IoT devices are constrained, with limited computing power and memory.

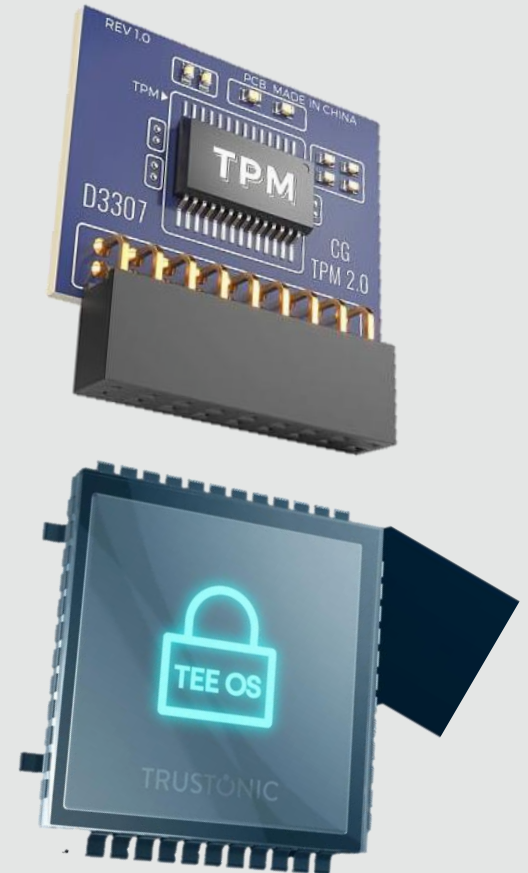


IoT device - Storing keys

- The keys are stored in specialised or secure hardware.
- Often in eFuses or one-time programmable (OTP) memory.
 - Data written to this memory can not be erased*
- The process of writing keys or certificate to the device is known as provisioning.
- Boot keys are normally provisioned by the manufacturer as part of the manufacturing process.
- Other keys may be provisioned at a later part of the device life-cycle.



Warning: Changing these values incorrectly may permanently damage this device!

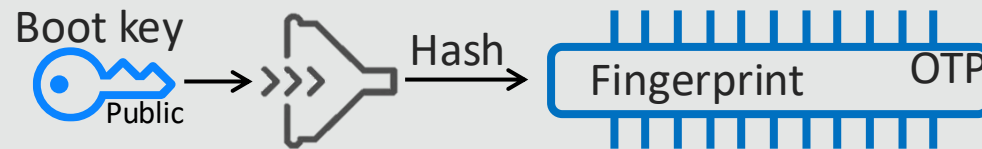


* Some can be erased by erasing the full memory

IoT device - Storing keys - Provision key

- Space in OTP memory is constrained
- The keys are stored as a *fingerprint*
 - The fingerprint is the hash of the key

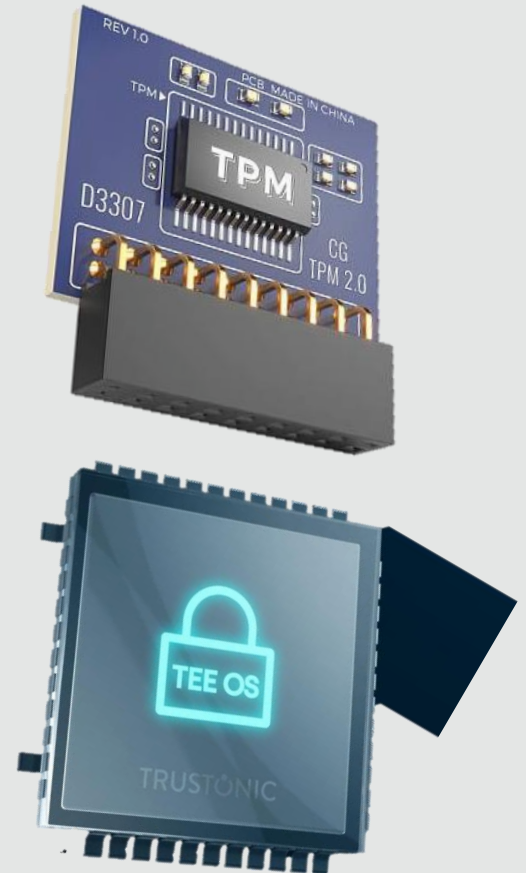
Provision Keys



- Multiple Boots can be provisioned so that keys can be be revoked later.

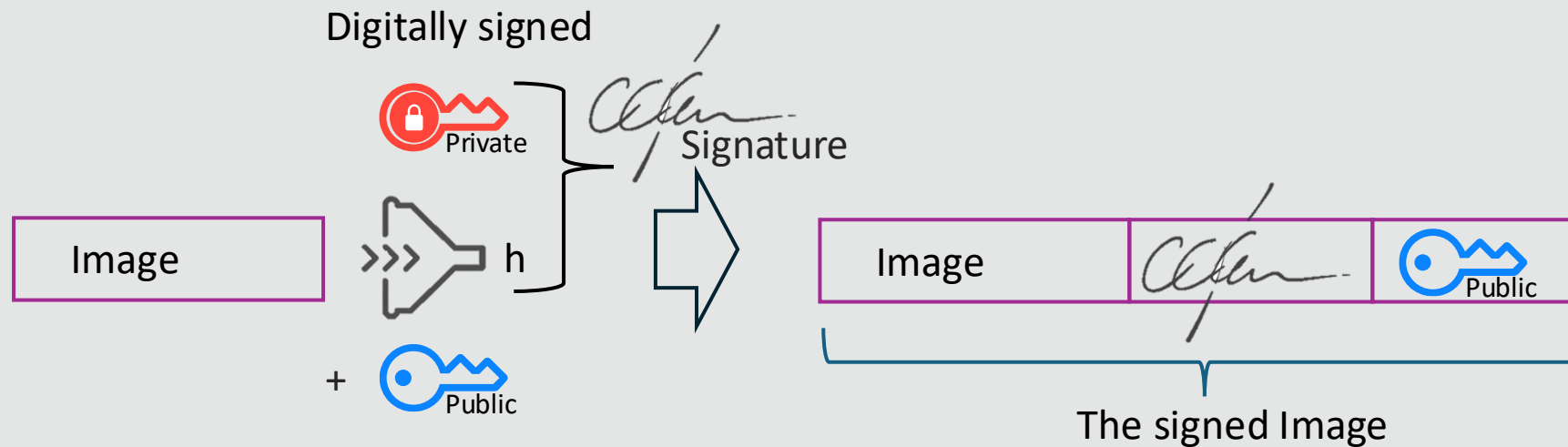


Warning: Changing these values incorrectly may permanently damage this device!

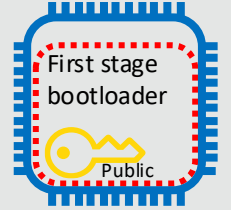


IoT device - Signing the image

- The second stage bootloader needs to be signed with the private key
- The image is then concatenated with the signature and public key



IoT device - Validating the image



- The image is validated in two steps

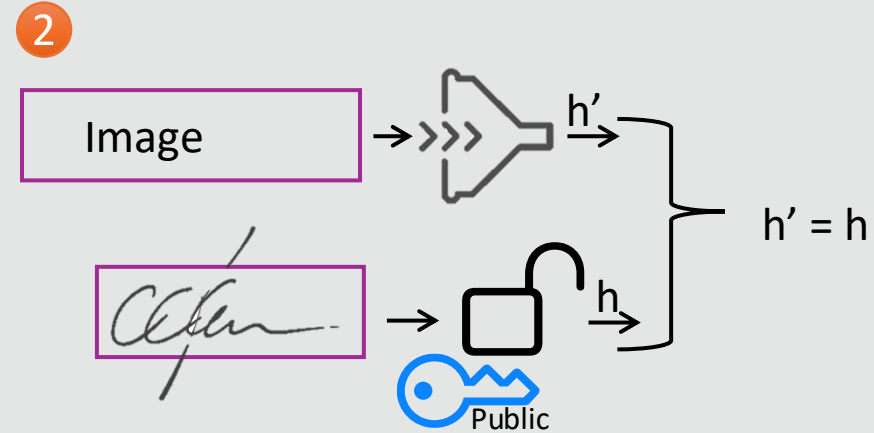


- The public key is validated with the fingerprint



- If the fingerprints are the same the public key can be used to validate the signature

- The public key is used to validate the signature



- If validation succeed, then image is executed

Image validation is not sufficient

The device need to be configured for security

- Any feature that could be used to update or change the boot image needs to be disable:
 - Debugging feature
 - JTAG port removed
 - The ability to write data to storage
 - Flash updates, write via USB
- Additional security features should also be enabled:
 - Encrypted flash
 - Protect OTP memory
 - Rollback protection



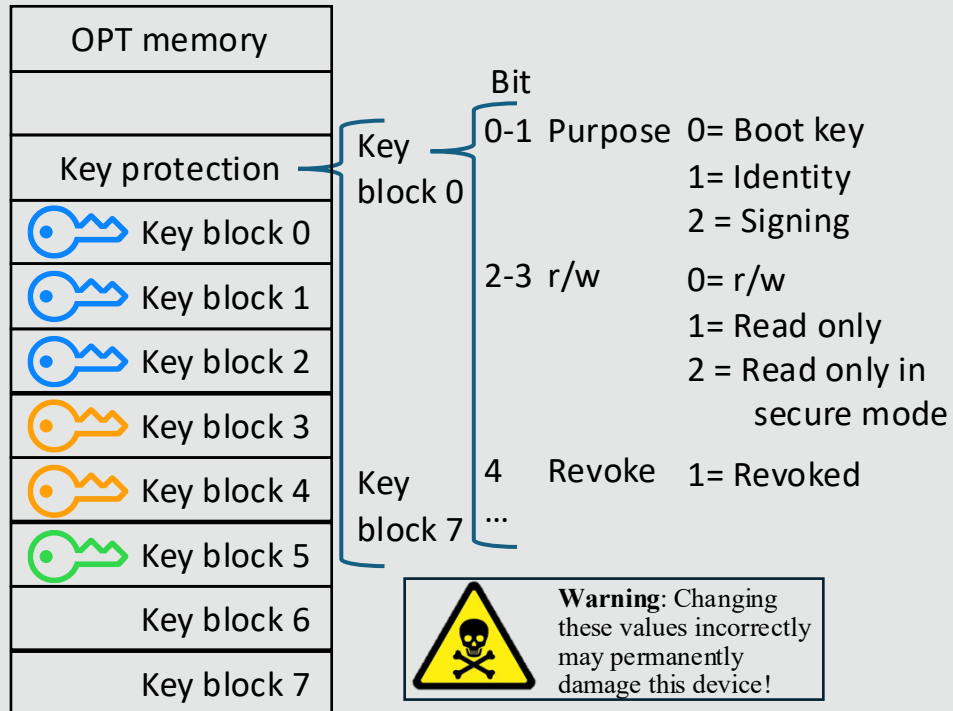
JTAG port left on a board



Anti-rollback

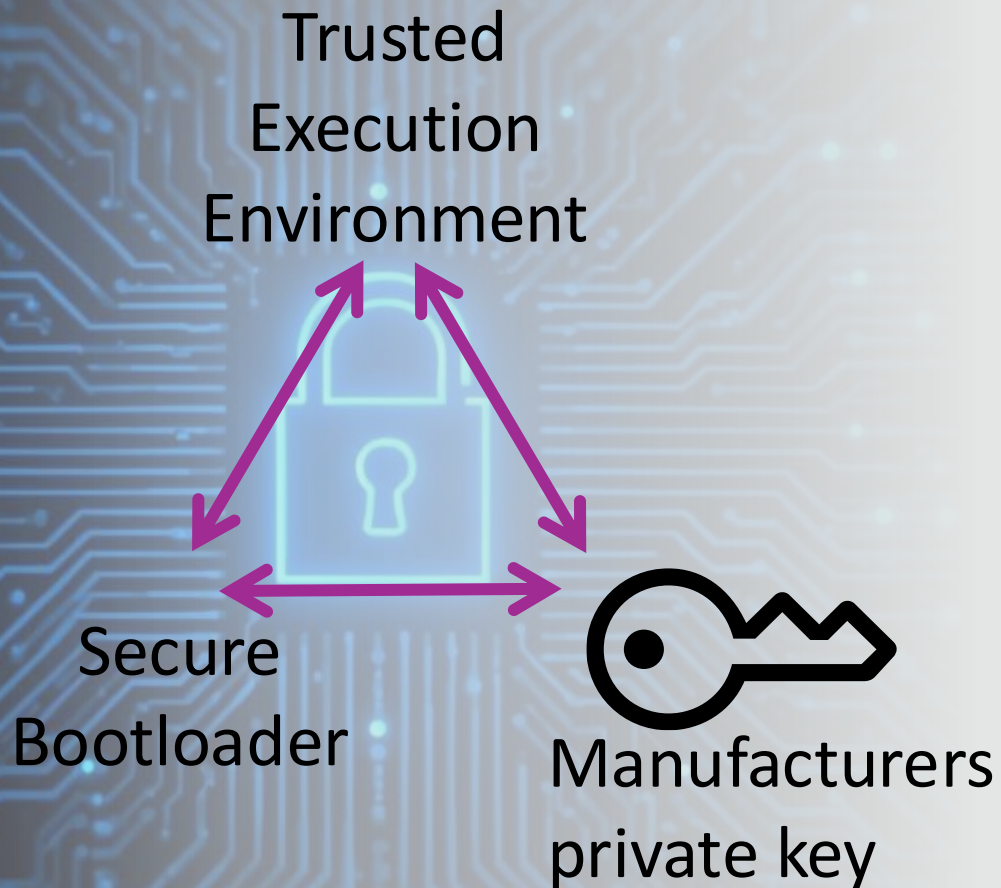
On-device key management

Example of Key configuration in OPT memory



- Device may have many different keys
 - Boot, Identity, attestation, encryption ...
- These keys need to be managed
 - Provisioned, permissioned, and revoked
- Key properties are configured in OPT memory

IoT Root of Trust

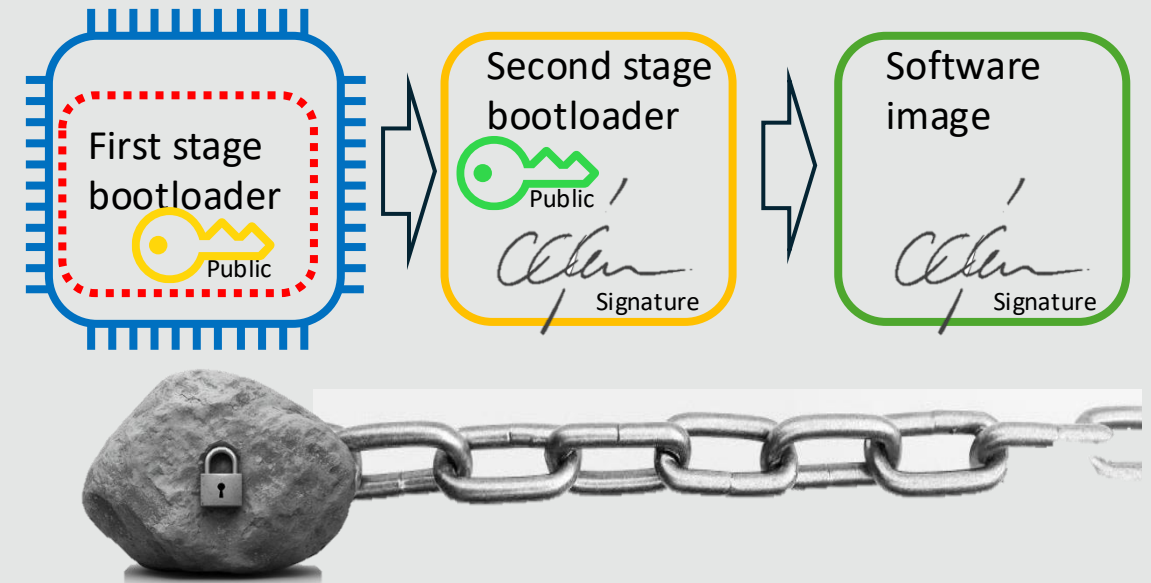


The Root of Trust is formed by:

- The secure hardware
- The secure bootloader
- The manufacturers private key

Chain of trust

- If any part of the process in compromised, then the chain is broken
 - The device is vulnerable
- If the keys are compromised
 - The device is vulnerable
- If the security configuration is wrong
 - The device is vulnerable



Implications for developers

- Testing secure boot is difficult
 - No debug, bad configuration could brick the drive, most IoT devices are different.
 - Testing is often done at the end of the development process
- Research has shown that:
 - Keys are really, if ever, updated.
 - Developer find the secure boot process difficult to implement



Secure boot lab

- Simulate the secure boot process
 - Loading and validating an image
 - image.sh
 - Generate the public and private key
 - Provision the public key
 - Sign the image
 - Write the code to validate the public key and signature
 - Using open ssl
- The lab will use ubuntu, open ssl and C



University of
BRISTOL



Questions



UNIVERSITY OF
BATH

